

HERRAMIENTAS DE PROGRAMACIÓN WEB DEL SERVIDOR

Tema 4 — Seguridad y Buenas Prácticas en Programación Web

Seguridad en Aplicaciones Web

Fundamentos, amenazas y arquitectura segura

1. Introducción

La seguridad en aplicaciones web es el conjunto de medidas, técnicas y buenas prácticas orientadas a proteger los sitios y sistemas que se ejecutan en un servidor frente a accesos no autorizados, robo de información, interrupción del servicio o manipulación de datos. A medida que las aplicaciones web gestionan información cada vez más sensible (datos personales, credenciales, transacciones financieras), la seguridad deja de ser un aspecto opcional y se convierte en un requisito indispensable del ciclo de vida del desarrollo de software.

En un entorno cliente-servidor, la superficie de ataque incluye el propio código de la aplicación, el servidor donde se aloja, la base de datos, las comunicaciones de red y, en muchos casos, el propio navegador del usuario. Por ello, la seguridad debe abordarse de forma integral, no como una capa añadida al final del desarrollo, sino como parte del diseño desde el inicio (principio de "seguridad por diseño" o security by design).

2. ¿Por qué es importante la seguridad web?

- **Protección de datos:** evita el robo o filtración de información personal, financiera o corporativa.
- **Continuidad del negocio:** un ataque exitoso puede dejar fuera de servicio una aplicación durante horas o días, generando pérdidas económicas.
- **Reputación:** una brecha de seguridad daña la confianza de los usuarios y clientes de forma difícil de recuperar.
- **Cumplimiento legal:** normativas como el RGPD exigen medidas mínimas de seguridad en el tratamiento de datos personales, con sanciones económicas en caso de incumplimiento (Parlamento Europeo y Consejo de la Unión Europea, 2016).
- **Coste del error:** corregir una vulnerabilidad detectada en producción es mucho más costoso que prevenirla durante el diseño o la codificación.

3. Principios fundamentales de la seguridad de la información

La seguridad de cualquier sistema, incluidas las aplicaciones web, se apoya tradicionalmente en tres pilares conocidos como la tríada CIA, presentes en guías de referencia como los principios de seguridad de Mozilla (Mozilla, s. f.):

- **Confidencialidad:** garantizar que la información solo sea accesible para quienes están autorizados a verla (por ejemplo, mediante cifrado y control de acceso).
- **Integridad:** asegurar que los datos no sean alterados de forma no autorizada, ni accidental ni maliciosamente.
- **Disponibilidad:** garantizar que el sistema y la información estén accesibles cuando los usuarios legítimos los necesiten.

A estos tres principios se suelen añadir otros dos, especialmente relevantes en aplicaciones web:

- **Autenticación:** verificar que un usuario es quien dice ser (contraseñas, tokens, autenticación multifactor).
- **Autorización:** una vez autenticado, controlar qué acciones y recursos puede utilizar cada usuario según su rol o permisos.

4. Principales amenazas y vectores de ataque

Las amenazas a las que se enfrenta una aplicación web pueden clasificarse según el punto del sistema que explotan, como recoge de forma sistemática el OWASP Top 10 (OWASP Foundation, 2021):

4.1 Amenazas a nivel de aplicación

- **Inyección de código:** SQL, comandos del sistema operativo o código script insertado a través de entradas de usuario no validadas.
- **Cross-Site Scripting (XSS):** inserción de scripts maliciosos que se ejecutan en el navegador de otros usuarios.
- **Cross-Site Request Forgery (CSRF):** engañar al navegador de un usuario autenticado para que realice acciones no deseadas.
- **Gestión de sesiones débil:** identificadores de sesión predecibles, ausencia de expiración o falta de cifrado en las cookies.

4.2 Amenazas a nivel de infraestructura

- **Configuración insegura del servidor:** puertos abiertos innecesarios, servicios desactualizados, credenciales por defecto.
- **Ataques de denegación de servicio (DoS/DDoS):** saturación del servidor mediante peticiones masivas.
- **Falta de cifrado en tránsito:** uso de HTTP en lugar de HTTPS, exponiendo datos a interceptación (ataques "man in the middle").

4.3 Amenazas relacionadas con el factor humano

- **Ingeniería social y phishing:** engaño a usuarios o administradores para obtener credenciales.
- **Contraseñas débiles o reutilizadas:** facilitan el acceso no autorizado mediante fuerza bruta o diccionarios.

5. Hacia una arquitectura segura

Diseñar una aplicación web segura implica aplicar de forma combinada varios principios arquitectónicos, entre los que destacan los siguientes (Mozilla, s. f.; Stuttard & Pinto, 2011):

- **Defensa en profundidad:** aplicar múltiples capas de seguridad (red, servidor, aplicación, base de datos) de modo que si una falla, las demás sigan protegiendo el sistema.

- **Principio de mínimo privilegio:** cada componente, proceso o usuario debe disponer únicamente de los permisos estrictamente necesarios para su función.
- **Superficie de ataque mínima:** deshabilitar servicios, puertos, funcionalidades o endpoints que no se utilicen.
- **Fail secure:** ante un fallo o excepción, el sistema debe quedar en un estado seguro (por ejemplo, denegando el acceso) en lugar de un estado permisivo.
- **Separación de entornos:** mantener entornos de desarrollo, pruebas y producción claramente diferenciados y con distintas credenciales.

En la segunda parte de este trabajo se abordará en detalle el OWASP Top 10, el listado de referencia internacional sobre los riesgos de seguridad más críticos en aplicaciones web, junto con sus contramedidas, así como un conjunto de buenas prácticas de codificación segura aplicables al desarrollo diario.

Referencias bibliográficas

- Mozilla. (s. f.). Web Security Guidelines. Mozilla Infosec. https://infosec.mozilla.org/guidelines/web_security
- National Institute of Standards and Technology. (2020). Digital Identity Guidelines: Authentication and Lifecycle Management (NIST SP 800-63B). U.S. Department of Commerce. <https://csrc.nist.gov/pubs/sp/800/63/b/upd2/final>
- OWASP Foundation. (2021). OWASP Top 10:2021 — The ten most critical web application security risks. <https://owasp.org/Top10/2021/>
- OWASP Foundation. (s. f.). OWASP Cheat Sheet Series. <https://cheatsheetseries.owasp.org/>
- Parlamento europeo y Consejo de la Unión Europea. (2016). Reglamento (UE) 2016/679, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales (RGPD). Diario Oficial de la Unión Europea, L 119. <https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=celex%3A32016R0679>
- Stuttard, D., & Pinto, M. (2011). The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws (2.^a ed.). Wiley.